

OPEN-SOURCE INTELLIGENCE EXERCISES

OPEN-SOURCE INTELLIGENCE (OSINT)

OSINT je obaveštajna delatost gde se javno dostupni podaci koriste u svrhu prikupljanja informacija o nekome/nečemu. Delatnost je prepoznata i od strane institucija i definisana zakonskim aktima. Na primer, američka vlada (US Department of Defense - [NATIONAL DEFENSE AUTHORIZATION ACT \(2006\)](#)) ga definiše na sledeći način:

1. Open-source intelligence (OSINT) is intelligence that is produced from publicly available information and is collected, exploited, and disseminated in a timely manner to an appropriate for the purpose of addressing a specific intelligence requirement.
2. With the Information Revolution, the amount, significance, and accessibility of open-source information has expanded significantly, but the intelligence community has not expanded its exploitation efforts and systems to produce open-source intelligence.
3. The production of open-source intelligence is a valuable intelligence discipline that must be integrated into intelligence tasking, collection, processing, exploitation, and dissemination to ensure that United States policymakers are fully and completely informed.

Ideja vežbe jeste da osvesti studente da postoji čitava disciplina koja se tiče otkrivanja podataka iz javnih izvora. Kako podaci mogu biti iskorišteni za napad na neki sistem, vrlo je bitno i o tome voditi računa. Pri tome, pretnja ne mora biti vrlo jasno vidljiva, poput slučaja kada je slučajno otkrivena lozinka. Može biti i podmuklija. Recimo, pronađeni podaci mogu biti iskorišteni za socijalni inženjering.

Na prethodnim terminima ste čak imali prilike da se oprobate u tome. U okviru Juice Shop platforme je jedan od zadataka bio da se pronađe odgovor na Bjoernovo bezbednosno pitanje, koji je on slučajno učinio javno dostupnim. A popričali smo i o ostavljanju tajni (lozinki, tokena...) na git repozitorijumu ☺

EXAMPLE 1 – CONDUCTING PASSIVE RECONNAISSANCE WITH GOOGLE DORKS

SUGGESTED READINGS

- <https://www.infosecinstitute.com/resources/penetration-testing/penetration-testing-intelligence-gathering/>

TUTORIAL

The Google Hacking Database (GHDB) is a categorized index of Internet search engine queries designed to uncover interesting, and usually sensitive, information made publicly available on the Internet. In most cases, this information was never meant to be made public but due to any number of factors this information was linked in a web document that was crawled by a search engine that subsequently followed that link and indexed the sensitive information.

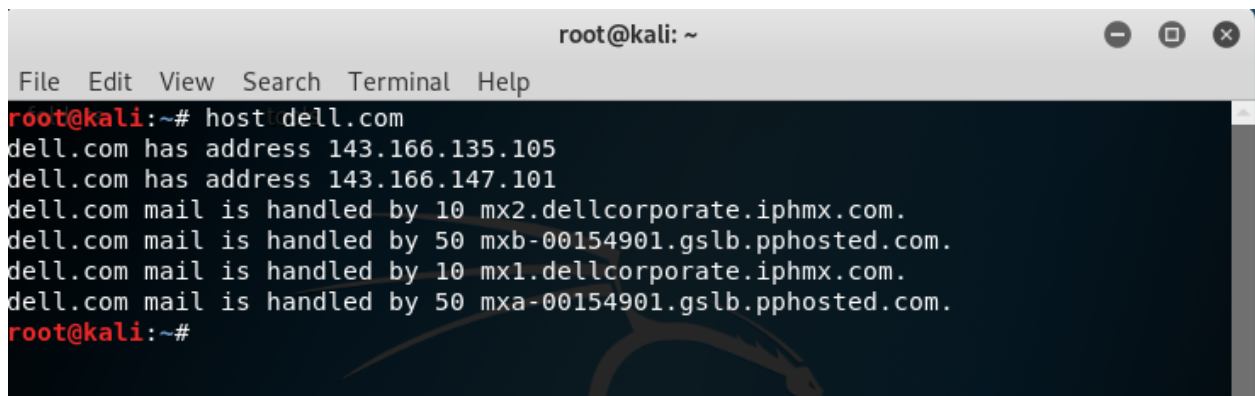
Go to the <https://www.exploit-db.com/google-hacking-database> and try out the queries for your favorite website.

EXAMPLE 2 – CONDUCTING PASSIVE RECONNAISSANCE WITH SHODAN

TUTORIAL

Shodan is a search engine for Internet-connected devices. Web search engines, such as Google and Bing, are great for finding websites. But what if you're interested in measuring which countries are becoming more connected? Or if you want to know which version of Microsoft IIS is the most popular? Or you want to find the control servers for malware? Maybe a new vulnerability came out and you want to see how many hosts it could affect? Traditional web search engines don't let you answer those questions. Shodan gathers information about all devices directly connected to the Internet. If a device is directly hooked up to the Internet, then Shodan queries it for various publicly-available information. The types of devices that are indexed can vary tremendously: ranging from small desktops up to nuclear power plants and everything in between. So, what does Shodan index then? The bulk of the data is taken from banners, which are metadata about a software that's running on a device. This can be information about the server software, what options the service supports, a welcome message or anything else that the client would like to know before interacting with the server.

In the following example, we'll perform some basic reconnaissance activity against Dell. We'll start by finding an IP address associated with a website we know belongs to Dell and this example we use dell.com.

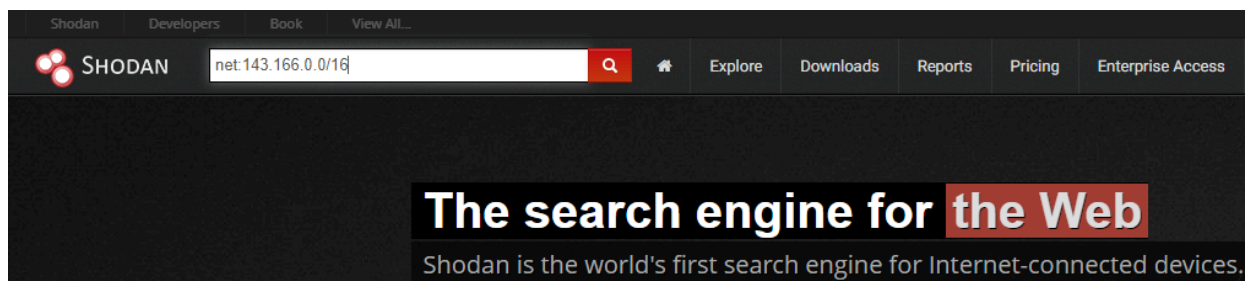
A terminal window titled 'root@kali: ~' with a menu bar (File, Edit, View, Search, Terminal, Help). The terminal output shows the command 'host dell.com' and its results: 'dell.com has address 143.166.135.105', 'dell.com has address 143.166.147.101', and four mail handling records for 'dell.com' with various mx and gslb domains. The prompt 'root@kali:~#' is visible at the bottom.

```
root@kali: ~
File Edit View Search Terminal Help
root@kali:~# host dell.com
dell.com has address 143.166.135.105
dell.com has address 143.166.147.101
dell.com mail is handled by 10 mx2.dellcorporate.iphmx.com.
dell.com mail is handled by 50 mxb-00154901.gslb.pphosted.com.
dell.com mail is handled by 10 mx1.dellcorporate.iphmx.com.
dell.com mail is handled by 50 mxa-00154901.gslb.pphosted.com.
root@kali:~#
```

You can see that when resolve IP addresses for this domain name, we get back several results. We'll copy the first example and perform whois: query to get additional information. We can see that this IP address is assigned to a network range and this network range has been assigned to Dell Inc.

```
root@kali: ~  
File Edit View Search Terminal Help  
root@kali:~# host dell.com  
dell.com has address 143.166.135.105  
dell.com has address 143.166.147.101  
dell.com mail is handled by 10 mx2.dellcorporate.iphmx.com.  
dell.com mail is handled by 50 mxb-00154901.gslb.pphosted.com.  
dell.com mail is handled by 10 mx1.dellcorporate.iphmx.com.  
dell.com mail is handled by 50 mxa-00154901.gslb.pphosted.com.  
root@kali:~# whois 143.166.135.105  
  
#  
# ARIN WHOIS data and services are subject to the Terms of Use  
# available at: https://www.arin.net/resources/registry/whois/tou/  
#  
# If you see inaccuracies in the results, please report at  
# https://www.arin.net/resources/registry/whois/inaccuracy\_reporting/  
#  
# Copyright 1997-2019, American Registry for Internet Numbers, Ltd.  
#  
  
NetRange:      143.166.0.0 - 143.166.255.255  
CIDR:          143.166.0.0/16  
NetName:       DELL  
NetHandle:     NET-143-166-0-0-1  
Parent:        NET143 (NET-143-0-0-0-0)  
NetType:       Direct Assignment  
OriginAS:        
Organization:  Dell, Inc. (DCC-25)  
RegDate:       1990-09-25  
Updated:       2018-03-06  
Ref:           https://rdap.arin.net/registry/ip/143.166.0.0
```

We'll copy this network range and we'll use a tool called shodan.io. Shodan regularly scans the internet for publicly accessible services and archives all of the results, along with fingerprinting on those services, in a searchable format. We will limit our search to addresses and network range belonging to Dell.



TOTAL RESULTS	
978	
TOP COUNTRIES	
	
United States	978
TOP SERVICES	
HTTPS	423
HTTP	383
NTP	41
SSH	29
HTTPS (8443)	20
TOP ORGANIZATIONS	
Dell	978
TOP OPERATING SYSTEMS	
Windows 7 or 8	10
Linux 3.x	1
Linux 2.4-2.6	1
TOP PRODUCTS	
Microsoft IIS httpd	385
Apache httpd	41
ntpd	40
Microsoft HTTPAPI httpd	39
OpenSSH	26

Login to the Customer Licensing Portal

143.166.156.171
 U2VMLTGSAPWEB1.us.dell.com
 Dell
 Added on 2019-04-09 19:12:31 GMT
 United States
 Technologies: IIS;confidence:50

SSL Certificate

Issued By:
 Common Name: Entrust Certification
 Authority - L1K
 Organization: Entrust, Inc.
 Issued To:
 Common Name: saplicenselink.dell.com
 Organization: Dell USA L.P.

HTTP/1.1 200 OK
 Cache-Control: private
 Content-Type: text/html; charset=utf-8
 Server: Microsoft-IIS/7.5
 X-AspNet-Version: 2.0.50727
 X-Powered-By: ASP.NET
 X-Frame-Options: SAMEORIGIN
 Date: Tue, 09 Apr 2019 19:12:30 GMT
 Content-Length: 9658

Supported SSL Versions
 TLSv1.2

143.166.82.247

u1vmamp002.aus.amer.dell.com
 multib2b.asap.com
 Dell
 Added on 2019-04-09 18:04:20 GMT
 United States

SSL Certificate

Issued By:
 Common Name: Entrust Certification
 Authority - L1K
 Organization: Entrust, Inc.
 Issued To:
 Common Name: multib2b.asap.com
 Organization: Dell USA L.P.

HTTP/1.1 401 [ISS.0084.9004] Access Denied
 Content-Type: text/html; charset=UTF-8
 Connection: close
 WWW-Authenticate: Basic realm="Integration Server", encoding="UTF-8"
 Content-Length: 48

Supported SSL Versions
 TLSv1.1

Diffie-Hellman Parameters
 Fingerprint: Java 7/Hardcoded 768-bit prime

403 - Forbidden: Access is denied.

143.166.135.101
 Dell
 Added on 2019-04-07 01:25:20 GMT
 United States

HTTP/1.1 403 Forbidden
 Content-Type: text/html
 Server: Microsoft-IIS/8.0
 X-Powered-By: ASP.NET
 X-Frame-Options: SAMEORIGIN
 Date: Tue, 09 Apr 2019 20:18:53 GMT
 Content-Length: 1233

We can see that there's a total of 978 services that Shodan is currently aware of. Shodan gives us a list of the most common services in this range including http, https, ssh, and vp unrelated services. We can also see operating systems that are available on these ranges and products that might be accessible. If we are interested in systems with ssh, we can go ahead and click on ssh and it will add a filter to limit our results to services in the Dell range that have ssh available.

TOTAL RESULTS	
37	
TOP COUNTRIES	
	
United States	37
TOP ORGANIZATIONS	
Dell	37
TOP OPERATING SYSTEMS	
Linux 3.x	1
TOP PRODUCTS	
OpenSSH	27

143.166.82.239

Dell
 Added on 2019-04-07 01:25:20 GMT
 United States

SSH-2,0-OpenSSH_6.6
 Key type: ssh-rsa
 Key: AAAAB3NzaC1yc2EAAAABIwAAQEAyF/Ip1C0a4CL6p0nJG/UuoJhV2T3BWEWZU5vv41x1Lfa20WYV2qtjSddZw7X/7LFG6PzqhChyF0n3NcLroBHP0uHvKR6UNNBQtPjT6VzP+/03UUK3R1Lm6g0R5Ly6qNMSLH+wQVK3q0zz0Ga4cu1aNoJh/wgfrn9dmkgBrxoy9Zod9xALeQh0Lx2Ztn1qK9C+Tw7xcyrGL7NND0+YLZFYCb+Cv5...

143.166.118.36

Dell
 Added on 2019-04-09 12:44:58 GMT
 United States

SSH-2,0-OpenSSH_6.6.1
 Key type: ssh-rsa
 Key: AAAAB3NzaC1yc2EAAAADAQABAAQCu1xqbT2+WQ7aah0YKfP101fViu/7Y8F4faZp7puTLaEgG7IY8a0J6f7B5Jq1Q3+YNCryS04Fdv8JubIrphET1D1H00t9Bm0cm7Jp93UUN8FcRdRmmsKQ0rqwHLi1aJ0aHHTFjppY3MazCXqcnBnp6u4XCnsuR2AgLbo6fph9E2uNEPxmQjF64X/05JLDiHxWrrIDoFoP0KtFL99zp003a...

143.166.82.41

AJSP/CBSINWEB03.us.dell.com
 Dell
 Added on 2019-04-09 18:10:57 GMT
 United States

SSH-2,0-OpenSSH_7.4
 Key type: ssh-rsa
 Key: AAAAB3NzaC1yc2EAAAADAQABAAQCBwPgeXJ362qWu1oH3rnskhNsb4kLgY1m+byQrqa08es2b1MyxPoGcZy386KntHj3GSG1mYfBmF571dsHRG9axriu3+NPE3HmWnMaxH7G01Lar6ZQWp48B4mvAZw5JLfxvIn0SvTVZ3H/r4yi/40dij6GZes05iyuNd1q5FYNGHm6xX0NMFc53ASvh2KxTKTERp0Hw/DKvI28w39/b05i...

We can click on any of the IP addresses and it will bring up additional information including host name, when it was last scanned, geographic information if it's available, as well as accessible ports on the system. So, in this case we can see there is port 22, or ssh, and port 443 and if we look at these services we see Shodan has kept fingerprinting information about these services which can be useful. In this case, we were able to gain a list of services that are accessible in a target network without having to send a single packet to that target network.

